UNIVERSIDAD DE LAS FUERZAS ARMADAS ESPE

Ingeniería de Software

KunturChat

Salas de chat seguras, vigiladas desde las alturas

Análisis y tratamiento de riesgos de seguridad del software

Proyecto Integrador

Asignatura: Desarrollo de Software Seguro
NRC: 36900

Integrantes

Altamirano Ricardo
Ayo Alisson
Valencia Yuliana

Sangolquí, Ecuador
12 de octubre de 2026

Índice

1. Propósito y contexto **2**
1.1. Qué es confirmado y qué es propuesto . . . 2
1.2. Roles . . . 2

2. Alcance y arquitectura de referencia **2**
2.1. Decisión de identidad . . . 3
2.2. Requisitos derivados . . . 3

3. Método de evaluación **3**
3.1. Pasos . . . 3
3.2. Escala de probabilidad (durante el piloto) . . . 4
3.3. Escala de impacto . . . 4
3.4. Niveles de riesgo y decisión . . . 4
3.5. Reglas de honestidad del análisis . . . 4

4. Políticas propuestas **4**
4.1. Normas y buenas prácticas usadas . . . 5

5. Inventario de 15 activos, amenazas y vulnerabilidades **5**

6. Registro consolidado de riesgos **6**
6.1. Balance . . . 7

7. Fichas de análisis, tratamiento y validación **7**
7.1. R01 Fuerza bruta contra el administrador . . . 7
7.2. R02 Suplantación en la API de autenticación . . . 7
7.3. R03 Modificación no autorizada de salas . . . 8
7.4. R04 Acceso a salas privadas . . . 9
7.5. R05 Escalada de privilegios . . . 9
7.6. R06 Secuestro o duplicación de sesiones . . . 10
7.7. R07 Intercepción del canal WebSocket . . . 10
7.8. R08 Alteración o suplantación de mensajes . . . 11
7.9. R09 Filtración de claves criptográficas . . . 11
7.10. R10 Carga de archivo malicioso . . . 12
7.11. R11 Descarga de archivos de otra sala . . . 12
7.12. R12 Contenido oculto por esteganografía . . . 13
7.13. R13 Manipulación de auditoría . . . 13
7.14. R14 Inyección SQL . . . 14
7.15. R15 Denegación de servicio (DoS) . . . 15

8. Flujo de archivos y límites de la protección **15**

9. Plan de tratamiento y gestión residual **16**

10. Indicadores de seguimiento **16**

11. Conclusiones **17**

Referencias **17**

1. Propósito y contexto

KunturChat es una aplicación web de salas de chat seguras. *Kúntur* significa cóndor en kichwa: un ave que vigila desde lo alto, igual que el sistema vigila quién entra, qué se envía y qué archivos circulan.

Este documento hace tres cosas:

1. Identifica **15 activos** del proyecto, cada uno con su amenaza y su vulnerabilidad.
2. Valora el riesgo **antes** del tratamiento (inherente) y **después** (residual).
3. Define para cada riesgo un **control** y una **prueba** que permitirá comprobarlo.

Resumen en un minuto. Un riesgo es *qué tan probable* es que algo salga mal (P) por *qué tan grave* sería (I): $R = P \times I$. Primero lo calculamos sin controles (riesgo inherente), luego aplicamos controles y lo recalculamos (riesgo residual). Los controles casi siempre bajan P; I solo baja cuando el control limita el daño. Los valores son estimaciones de diseño: se confirmarán con las pruebas.

1.1. Qué es confirmado y qué es propuesto

Tipo	Descripción
Confirmado	Requisitos del proyecto integrador: administración con usuario y contraseña; salas con identificador, clave, aforo y modo (texto o multimedia); una conexión por usuario o dispositivo; protección criptográfica; validación de multimedia; detección de posible esteganografía; auditoría.
Propuesto	Aplicación web con HTTPS/WSS, backend central, base de datos relacional, almacén de sesiones y un módulo aislado de análisis multimedia. Es una arquitectura de referencia, no una implementación observada.
Supuesto	Piloto académico de tres meses, expuesto por red, con pocas salas y hasta 50 usuarios simultáneos en pruebas de carga.
Pendiente	Código, tecnologías definitivas, formatos multimedia finales y volumen real. Si cambian, se recalculan P e I.

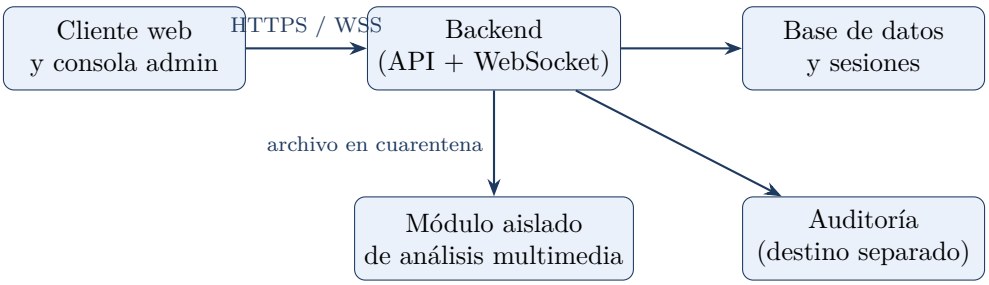
1.2. Roles

- **Administrador:** crea, modifica y cierra salas.
- **Participante:** ingresa a salas con clave y conversa.
- **Equipo de desarrollo:** implementa controles y ejecuta pruebas.
- **Responsable del proyecto:** aprueba el tratamiento y cualquier aceptación de riesgo.

2. Alcance y arquitectura de referencia

Alcance SGSI: frontend, backend, APIs, canal WebSocket, salas, autenticación, sesiones, multimedia, auditoría, base de datos y cifrado.

Fuera del alcance: seguridad de los dispositivos personales, disponibilidad de la red del proveedor y audio o video (el piloto propone solo PNG y JPEG). No se afirma certificación ISO/IEC 27001; las normas se usan como guía.



Cómo leerlo: el navegador no es confiable, por eso toda validación y autorización ocurre en el backend. Los archivos solo se publican después de que el módulo de análisis los apruebe.

2.1. Decisión de identidad

La clave de sala permite entrar a esa sala, pero *no* identifica a una persona. Por eso se propone una cuenta de participante con identificador estable y una sesión ligada a ella. La regla de "una conexión" se aplica a esa identidad. La IP o la huella del navegador no bastan para probar que es un único dispositivo físico.

2.2. Requisitos derivados

ID	Requisito
RF01	Autenticación segura del administrador.
RF02	Crear, modificar, consultar y cerrar salas.
RF03	Cada sala con identificador, clave, aforo y modo propios.
RF04	Una sola conexión activa por identidad.
RF05	Autenticación y autorización de cada acción.
RF06	Confidencialidad, integridad y autenticidad de la comunicación.
RF07	Validación previa de archivos multimedia.
RF08	Detección de indicios de esteganografía y aplicación de política.
RF09	Registro y alerta de eventos de seguridad.

3. Método de evaluación

3.1. Pasos

1. **Identificar:** activo, amenaza y vulnerabilidad.
2. **Describir** un escenario por activo.
3. **Valorar** P e I del 1 al 5.
4. **Calcular:**
$$R_{inherente} = P_{inh} \times I_{inh} \qquad R_{residual} = P_{res} \times I_{res}$$
5. **Tratar:** elegir control, definir prueba y estimar el residual.

Definiciones. *Activo:* lo que vale la pena proteger. *Amenaza:* lo que puede pasar. *Vulnerabilidad:* la debilidad que lo permite. *Riesgo:* el escenario con su consecuencia. *Control:* la medida que baja P o I.

La multiplicación es una convención del equipo para priorizar. Es una matriz ordinal: no calcula dinero perdido ni frecuencias reales.

3.2. Escala de probabilidad (durante el piloto)

P	Categoría	Criterio
1	Rara	Hay que romper una barrera robusta ya verificada.
2	Poco probable	Hay barreras eficaces; se requiere una técnica específica o un fallo adicional.
3	Posible	Existe una vía viable, pero necesita una condición particular (acceso, archivo, secreto).
4	Probable	La superficie es accesible y el intento es fácil y repetible.
5	Casi segura	Explotación ya reproducida. No se asigna sin evidencia.

3.3. Escala de impacto

Se toma el **máximo** entre confidencialidad (C), integridad (I) y disponibilidad (D) afectadas; no se suman.

I	Categoría	Consecuencia de referencia
1	Insignificante	Sin datos reservados expuestos; interrupción menor a 5 minutos.
2	Menor	Afectación limitada y reversible; interrupción de 5 a 30 minutos.
3	Moderado	Una identidad comprometida o mensajes alterados; interrupción de 30 minutos a 2 horas.
4	Grave	Contenido reservado de una sala expuesto o varias sesiones comprometidas; interrupción de 2 a 8 horas.
5	Crítico	Acceso a múltiples salas o control administrativo; interrupción mayor a 8 horas o pérdida irrecuperable.

3.4. Niveles de riesgo y decisión

Puntaje	Nivel	Decisión propuesta
1 a 5	Bajo	Aceptar con registro; revisión mensual.
6 a 10	Medio-Bajo	Aceptar con evidencia y monitoreo; revisión quincenal.
11 a 15	Medio-Alto	Tratar en la iteración actual antes de liberar.
16 a 25	Alto	No liberar el componente hasta tratarlo y reevaluarlo.

Que un riesgo quede en nivel bajo no elimina el requisito obligatorio: las pruebas de acceso, sesión única, cifrado, validación y esteganálisis se hacen igual.

3.5. Reglas de honestidad del análisis

- Si falta evidencia, se mantiene la valoración inicial y se registra la incertidumbre.
- *I* baja solo si el control *limita el daño*, no por tener más controles.
- Si una prueba falla, el residual no se acredita.
- Se reevalúa ante cambios de formato, arquitectura o incidentes.

4. Políticas propuestas

Zero Trust se concreta en validar identidad y permisos en cada acción. Secure by Design, en separar funciones antes de programar. Shift Left Security, en probar desde el diseño. Los umbrales numéricos son decisiones del piloto, no mandatos de ISO.

Código	Política	Regla	Riesgos
POL01	Identidad y secretos	MFA para administradores; claves de sala aleatorias; contraseñas con hash; rotación controlada.	R01, R04
POL02	Sesiones	Una conexión por identidad; expiración y revocación inmediata.	R02, R06
POL03	Autorización	Denegar por defecto; verificar rol, membresía, modo y aforo en el servidor.	R03, R05
POL04	Criptografía	HTTPS/WSS; cifrado autenticado de mensajes y archivos; claves fuera del código.	R07, R08, R09
POL05	Entradas y código	Validación en servidor; consultas parametrizadas; revisión de código.	R14
POL06	Multimedia	Solo PNG/JPEG; cuarentena; análisis aislado antes de publicar.	R10, R11, R12
POL07	Auditoría	Registros en destino separado, sin mensajes ni tokens; alertas.	R13
POL08	Capacidad	Cuotas, límites de tasa y recuperación probados.	R15

4.1. Normas y buenas prácticas usadas

Referencia	Uso en el proyecto
ISO/IEC 27001	Guía de gestión del riesgo y de revisión continua.
ISO/IEC 27005	Método de valoración y tratamiento del riesgo.
ISO/IEC 27034	Seguridad integrada en el ciclo de la aplicación.
NIST SP 800-207	Principios Zero Trust.
OWASP Cheat Sheets	Controles concretos: sesiones, XSS, SQLi, subida de archivos, logs.

Se usan como orientación, sin declarar conformidad ni certificación.

5. Inventario de 15 activos, amenazas y vulnerabilidades

ID	Activo	Amenaza	Vulnerabilidad	Dim.
A01	Credenciales del administrador	Fuerza bruta	Sin límite de intentos ni segundo factor	C
A02	API de autenticación	Suplantación de identidad	Tokens inseguros o validación insuficiente	C, I
A03	API de gestión de salas	Cambios no autorizados	Falta de autorización por operación	I
A04	Identificadores y claves de salas	Acceso a salas privadas	Claves débiles o IDs predecibles	C
A05	Roles y permisos	Escalada de privilegios	Permisos excesivos o incompletos	C, I
A06	Gestor de sesiones y dispositivos	Secuestro o duplicación de sesión	Sesiones que no se invalidan	I
A07	Conexiones WebSocket	Intercepción de tráfico	Canal sin TLS o con controles débiles	C, I
A08	Mensajes de chat	Alteración o falsa atribución	Sin verificación de integridad ni de remitente	I
A09	Claves criptográficas	Robo o filtración de secretos	Almacenamiento inseguro	C, I

ID	Activo	Amenaza	Vulnerabilidad	Dim.
A10	API de carga de archivos	Carga de malware	Validación de archivos insuficiente	C, I
A11	Almacenamiento multimedia	Lectura de archivos ajenos	Autorización de descarga insuficiente	C
A12	Módulo de esteganografía	Contenido oculto malicioso	Análisis inexistente o insuficiente	I, C
A13	Registros de auditoría	Alteración de evidencias	Permisos excesivos sobre las bitácoras	I, D
A14	Base de datos	Inyección SQL	Consultas sin parametrizar	C, I, D
A15	Servidor backend y APIs	Denegación de servicio	Sin límites de tráfico ni de recursos	D

C: confidencialidad, I: integridad, D: disponibilidad. La columna indica las dimensiones del escenario elegido, no todas las del activo. Los nombres de rutas API son ejemplos de diseño.

6. Registro consolidado de riesgos

Cada fila corresponde a la ficha R del mismo número. P_r e I_r son los valores residuales objetivo.

ID	Escenario	P	I	RI	Nivel	P_r	I_r	RR	Estado
R01	Fuerza bruta al administrador	4	5	20	Alto	2	4	8	Medio-Bajo
R02	Suplantación en la API de autenticación	4	5	20	Alto	2	4	8	Medio-Bajo
R03	Modificación no autorizada de salas	4	4	16	Alto	2	3	6	Medio-Bajo
R04	Acceso a salas privadas	4	5	20	Alto	2	4	8	Medio-Bajo
R05	Escalada de privilegios	3	5	15	Medio-Alto	2	3	6	Medio-Bajo
R06	Secuestro o duplicación de sesiones	4	4	16	Alto	2	3	6	Medio-Bajo
R07	Intercepción del canal WebSocket	3	5	15	Medio-Alto	1	4	4	Bajo
R08	Alteración o suplantación de mensajes	3	5	15	Medio-Alto	1	4	4	Bajo
R09	Filtración de claves criptográficas	3	5	15	Medio-Alto	2	3	6	Medio-Bajo
R10	Carga de archivo malicioso	4	4	16	Alto	2	4	8	Medio-Bajo
R11	Descarga de archivos de otra sala	4	4	16	Alto	2	3	6	Medio-Bajo
R12	Contenido oculto por esteganografía	3	4	12	Medio-Alto	2	3	6	Medio-Bajo
R13	Manipulación de auditoría	3	4	12	Medio-Alto	1	4	4	Bajo
R14	Inyección SQL	4	4	16	Alto	2	3	6	Medio-Bajo
R15	Denegación de servicio (DoS)	4	4	16	Alto	2	4	8	Medio-Bajo

6.1. Balance

Nivel	Antes (RI)	Después (RR)
Alto	9	0
Medio-Alto	6	0
Medio-Bajo	0	12
Bajo	0	3

Son conteos de escenarios, no una suma de pérdidas ni una medida global de seguridad: las escalas son ordinales y varios escenarios dependen entre sí.

Dependencias entre riesgos. R02 (tokens) puede facilitar R06 (secuestro de sesión); R09 (claves) puede agravar R07 y R08; R10 (carga de archivos) puede encadenarse con R15 (saturación); R13 (auditoría) afecta la detección de todos los demás.

Sensibilidad. Si la evidencia muestra que R12 es fácil de repetir, su P sube a 4 y pasa a 16 (Alto). Si el detector no cumple sus pruebas, su residual de 6 no se declara alcanzado.

7. Fichas de análisis, tratamiento y validación

Cada ficha responde cinco preguntas: ¿qué se protege?, ¿qué puede fallar?, ¿cuánto vale el riesgo y por qué?, ¿qué control se aplica? y ¿cómo se comprueba?

7.1. R01 Fuerza bruta contra el administrador

Elemento	Descripción
Activo	A01 Credenciales del administrador. Dimensión: C.
Amenaza	Un atacante prueba contraseñas de forma automatizada o reutiliza credenciales filtradas.
Vulnerabilidad	Acceso solo con contraseña, sin segundo factor y sin límite de intentos.
Consecuencia	Toma de la cuenta que gobierna todas las salas.
Probabilidad	$P = 4$: la consola es alcanzable por red y los intentos son repetibles con herramientas comunes.
Impacto	$I = 5$: una cuenta administrativa afecta a todas las salas.
Riesgo inherente	$4 \times 5 = 20$ – Alto
Control	MFA obligatorio (TOTP); hash Argon2id con sal individual; bloqueo progresivo por cuenta y origen; reautenticación para operaciones destructivas; alerta por intentos fallidos.
Prueba	Contraseña correcta sin segundo factor: se deniega. 20 intentos fallidos en un minuto: se activa el bloqueo y queda registrado. Revisar que no existan contraseñas en claro.
Riesgo residual	$2 \times 4 = 8$ – Medio-Bajo. P baja por MFA y bloqueo; I baja a 4 porque la reautenticación y las alertas limitan el daño de una sesión robada.
Riesgo que queda	Phishing del segundo factor o dispositivo del administrador comprometido.
Trazabilidad	RF01; POL01; Anexo A: A.5.17, A.8.5. Estado: propuesto, no probado.

7.2. R02 Suplantación en la API de autenticación

Elemento	Descripción
Activo	A02 API de autenticación. Dimensiones: C, I.
Amenaza	Un atacante se hace pasar por un usuario usando un token falsificado, robado o expirado.
Vulnerabilidad	Tokens sin firma robusta, sin expiración o sin validación completa en cada petición.
Consecuencia	Acceso con los permisos de otra identidad, incluida la administrativa.
Probabilidad	$P = 4$: la API es pública y probar tokens manipulados es sencillo.
Impacto	$I = 5$: si el token es de un administrador, se compromete toda la plataforma.
Riesgo inherente	$4 \times 5 = 20$ – Alto
Control	Tokens firmados con expiración corta; validar firma, emisor y vigencia en cada petición y en el handshake WebSocket; lista de revocación; rotación de claves de firma; tokens fuera de URL y logs.
Prueba	Enviar tokens alterados, expirados y revocados por HTTP y WebSocket: todos se rechazan. Verificar que el token no aparece en registros.
Riesgo residual	$2 \times 4 = 8$ – Medio-Bajo. P baja a 2; I baja a 4 porque la expiración corta limita el tiempo de uso de un token robado.
Riesgo que queda	Malware en el dispositivo del usuario o robo del token antes de su expiración.
Trazabilidad	RF05; POL02; Anexo A: A.8.5, A.8.26. Estado: propuesto, no probado.

7.3. R03 Modificación no autorizada de salas

Elemento	Descripción
Activo	A03 API de gestión de salas. Dimensión: I.
Amenaza	Un participante envía directamente una petición para editar o cerrar una sala.
Vulnerabilidad	La autorización se hace solo en la interfaz (botones ocultos) y no en el servidor.
Consecuencia	Cambio de aforo, modo o cierre de salas ajenas.
Probabilidad	$P = 4$: construir una petición manual es fácil y no requiere recursos especiales.
Impacto	$I = 4$: se altera la configuración de una o varias salas, sin control total de la plataforma.
Riesgo inherente	$4 \times 4 = 16$ – Alto
Control	RBAC en el backend con denegación por defecto; verificación de rol por recurso y acción; historial de cambios de configuración que permite revertir.
Prueba	Un participante intenta crear, editar y cerrar una sala por HTTP y WebSocket: todo se deniega. Matriz de pruebas por rol.
Riesgo residual	$2 \times 3 = 6$ – Medio-Bajo. I baja a 3 porque el historial permite revertir el cambio.
Riesgo que queda	Error en una operación nueva o abuso de un administrador legítimo.

Elemento	Descripción
Trazabilidad	RF02, RF05; POL03; Anexo A: A.5.15, A.8.3. Estado: propuesto, no probado.

7.4. R04 Acceso a salas privadas

Elemento	Descripción
Activo	A04 Identificadores y claves de salas. Dimensión: C.
Amenaza	Un tercero adivina el identificador y la clave de una sala privada.
Vulnerabilidad	Claves cortas, IDs consecutivos o predecibles e intentos ilimitados.
Consecuencia	Lectura de todo el contenido de una sala por personas no invitadas.
Probabilidad	$P = 4$: el formulario de ingreso permite repetir intentos con bajo costo.
Impacto	$I = 5$: se expone el contenido de la sala; se asigna el nivel máximo porque pueden ser salas con información sensible de varias personas.
Riesgo inherente	$4 \times 5 = 20$ – Alto
Control	Claves generadas con generador criptográfico (mínimo 128 bits); IDs aleatorios; solo se guarda el hash de la clave; límite de intentos por sala, identidad y origen; rotación de clave con revocación de membresías.
Prueba	20 claves incorrectas en un minuto: se aplica el límite sin revelar si la sala existe. Tras rotar la clave, la anterior deja de funcionar.
Riesgo residual	$2 \times 4 = 8$ – Medio-Bajo. P baja a 2; I sigue en 4 porque un invitado puede compartir la clave o conservar lo recibido.
Riesgo que queda	Divulgación voluntaria de la clave por un participante.
Trazabilidad	RF03; POL01; Anexo A: A.5.15, A.5.17. Estado: propuesto, no probado.

7.5. R05 Escalada de privilegios

Elemento	Descripción
Activo	A05 Roles y permisos. Dimensiones: C, I.
Amenaza	Un usuario obtiene permisos de un rol superior.
Vulnerabilidad	Permisos excesivos, rol aceptado desde el cliente o verificación incompleta.
Consecuencia	Un participante actúa como administrador de sala o de plataforma.
Probabilidad	$P = 3$: requiere encontrar una operación mal protegida.
Impacto	$I = 5$: un rol alto abre acceso a múltiples salas.
Riesgo inherente	$3 \times 5 = 15$ – Medio-Alto
Control	Mínimo privilegio; rol siempre leído desde el servidor; separación entre rol de administrador de salas y de plataforma; revisión de la matriz de permisos en cada entrega.
Prueba	Intentar enviar un campo `rol` manipulado y acceder a operaciones de otros roles: se rechaza. Revisión mensual de roles.
Riesgo residual	$2 \times 3 = 6$ – Medio-Bajo. I baja a 3 porque la separación de roles limita el alcance a una sala.

Elemento	Descripción
Riesgo que queda	Roles mal asignados por error humano.
Trazabilidad	RF05; POL03; Anexo A: A.5.15, A.8.3. Estado: propuesto, no probado.

7.6. R06 Secuestro o duplicación de sesiones

Elemento	Descripción
Activo	A06 Gestor de sesiones y dispositivos. Dimensión: I.
Amenaza	Un usuario abre dos conexiones a la vez, o un atacante reutiliza una sesión ajena.
Vulnerabilidad	La comprobación y el registro de la sesión se hacen en pasos separados, sin operación atómica; las sesiones no se invalidan.
Consecuencia	Se incumple la regla de una conexión y se pierde trazabilidad.
Probabilidad	$P = 4$: provocar dos conexiones simultáneas es fácil.
Impacto	$I = 4$: se puede actuar con una identidad ajena dentro de sus salas.
Riesgo inherente	$4 \times 4 = 16$ – Alto
Control	Restricción única por identidad con operación atómica; rechazo de la segunda conexión; expiración por inactividad; revocación inmediata al cerrar sesión y cierre de sockets.
Prueba	100 pares de conexiones simultáneas con la misma identidad: solo una queda activa. Cerrar sesión y reutilizar el token: denegado.
Riesgo residual	$2 \times 3 = 6$ – Medio-Bajo. I baja a 3 porque la revocación limita el tiempo de uso indebido.
Riesgo que queda	Una persona con dos cuentas distintas; se garantiza una conexión por identidad, no por persona física.
Trazabilidad	RF04; POL02; Anexo A: A.5.16, A.8.26. Estado: propuesto, no probado.

7.7. R07 Intercepción del canal WebSocket

Elemento	Descripción
Activo	A07 Conexiones WebSocket. Dimensiones: C, I.
Amenaza	Un intermediario lee o modifica el tráfico entre el cliente y el servidor.
Vulnerabilidad	Uso de `ws://` o `http://` sin cifrado, o aceptación de certificados inválidos.
Consecuencia	Exposición de mensajes y credenciales durante el tránsito.
Probabilidad	$P = 3$: requiere posición en la red, pero es viable si el canal no está cifrado.
Impacto	$I = 5$: se pueden capturar credenciales y conversaciones completas.
Riesgo inherente	$3 \times 5 = 15$ – Medio-Alto
Control	HTTPS y WSS con TLS 1.3; certificado válido; bloqueo del tráfico en claro; validación del encabezado Origin; autenticación durante el handshake.
Prueba	Capturar tráfico de prueba: sin mensajes ni secretos en claro. Conexión por `ws://` o con certificado inválido: se rechaza.

Elemento	Descripción
Riesgo residual	$1 \times 4 = 4$ – Bajo. P baja a 1 porque leer el tráfico exige romper TLS bien configurado; I baja a 4 porque se limita al canal interceptado.
Riesgo que queda	Dispositivos comprometidos; TLS no oculta el contenido al propio servidor.
Trazabilidad	RF06; POL04; Anexo A: A.8.20, A.8.24. Estado: propuesto, no probado.

7.8. R08 Alteración o suplantación de mensajes

Elemento	Descripción
Activo	A08 Mensajes de chat. Dimensión: I.
Amenaza	Un usuario falsifica el remitente de un mensaje o repite uno ya enviado.
Vulnerabilidad	El servidor confía en el campo remitente que envía el cliente y no controla duplicados ni integridad.
Consecuencia	Mensajes atribuidos a otra persona o conversaciones alteradas.
Probabilidad	$P = 3$: se necesita estar dentro de la sala, pero modificar campos es sencillo.
Impacto	$I = 5$: se rompe la confianza en toda la conversación y puede usarse para engaño dirigido.
Riesgo inherente	$3 \times 5 = 15$ – Medio-Alto
Control	El remitente se obtiene de la sesión del servidor, nunca del cliente; cifrado autenticado (AES-GCM) que detecta modificaciones; número de secuencia por sala; identificadores únicos para descartar repeticiones.
Prueba	Enviar un remitente falso: se ignora. Modificar un mensaje cifrado: falla la verificación. Repetir el mismo identificador 100 veces: se entrega una sola vez.
Riesgo residual	$1 \times 4 = 4$ – Bajo. P baja a 1 porque el servidor ya no acepta el remitente del cliente; I baja a 4 porque la secuencia delimita el alcance de una alteración.
Riesgo que queda	Un usuario autorizado puede publicar información falsa con su propia identidad.
Trazabilidad	RF05, RF06; POL04; Anexo A: A.8.24, A.8.26. Estado: propuesto, no probado.

7.9. R09 Filtración de claves criptográficas

Elemento	Descripción
Activo	A09 Claves criptográficas. Dimensiones: C, I.
Amenaza	Un tercero obtiene secretos publicados en un repositorio, imagen de despliegue o copia de configuración.
Vulnerabilidad	Claves guardadas en el código o en archivos de configuración, sin rotación ni permisos separados.
Consecuencia	Descifrado de datos y uso no autorizado de servicios internos.
Probabilidad	$P = 3$: requiere acceso a un artefacto, pero una filtración de código lo facilita.

Elemento	Descripción
Impacto	$I = 5$: una clave de servicio puede afectar a varias salas.
Riesgo inherente	$3 \times 5 = 15$ – Medio-Alto
Control	Gestor de secretos (vault) con acceso por identidad de servicio; escaneo de secretos en cada commit; claves separadas por sala o por dominio; rotación ante sospecha de compromiso.
Prueba	Escanear historial y artefactos: cero secretos activos. Rotar una clave de prueba y verificar que la anterior queda rechazada.
Riesgo residual	$2 \times 3 = 6$ – Medio-Bajo. I baja a 3 porque las claves por sala reducen el daño de una filtración.
Riesgo que queda	El servicio autorizado necesita acceso a claves; si se compromete, puede exponerlas. Rotar no recupera lo ya descifrado.
Trazabilidad	RF06; POL04; Anexo A: A.8.24. Estado: propuesto, no probado.

7.10. R10 Carga de archivo malicioso

Elemento	Descripción
Activo	A10 API de carga de archivos. Dimensiones: C, I.
Amenaza	Un usuario sube un archivo dañino disfrazado de imagen.
Vulnerabilidad	Se acepta el archivo por su extensión o tipo declarado, sin verificar su contenido real.
Consecuencia	Distribución de contenido dañino a los demás participantes de la sala.
Probabilidad	$P = 4$: renombrar un archivo es trivial y la sala multimedia permite subidas.
Impacto	$I = 4$: los destinatarios de una sala pueden quedar expuestos; no se asume compromiso de todo el sistema.
Riesgo inherente	$4 \times 4 = 16$ – Alto
Control	Lista permitida (solo PNG y JPEG); validar firma del archivo y decodificarlo; tamaño máximo; análisis antimalware; cuarentena antes de compartir; nombres aleatorios; almacenamiento fuera de la ruta pública.
Prueba	Subir un ejecutable renombrado, una imagen truncada y un archivo de prueba antimalware inocuo: todos se rechazan o quedan en cuarentena y no se publican.
Riesgo residual	$2 \times 4 = 8$ – Medio-Bajo. P baja a 2; I sigue en 4.
Riesgo que queda	Malware desconocido o explotación de visores desactualizados; el antimalware no garantiza ausencia de esteganografía.
Trazabilidad	RF07; POL06; Anexo A: A.8.7, A.8.26. Estado: propuesto, no probado.

7.11. R11 Descarga de archivos de otra sala

Elemento	Descripción
Activo	A11 Almacenamiento multimedia. Dimensión: C.
Amenaza	Un usuario accede a archivos de salas a las que no pertenece.
Vulnerabilidad	Descargas autorizadas solo por la URL, con identificadores predecibles.

Elemento	Descripción
Consecuencia	Exposición de archivos compartidos en salas privadas.
Probabilidad	$P = 4$: probar identificadores de archivo es sencillo y repetible.
Impacto	$I = 4$: se exponen archivos de una o más salas.
Riesgo inherente	$4 \times 4 = 16$ – Alto
Control	Verificar membresía de la sala en cada descarga; enlaces temporales firmados; IDs aleatorios; cifrado de archivos en reposo con claves separadas.
Prueba	Descargar un archivo con un usuario que no es miembro: denegado. Un enlace vencido deja de funcionar.
Riesgo residual	$2 \times 3 = 6$ – Medio-Bajo. I baja a 3 porque el cifrado en reposo limita lo que se expone si se accede al almacenamiento.
Riesgo que queda	Un miembro legítimo puede reenviar un archivo ya descargado.
Trazabilidad	RF05, RF07; POL03, POL06; Anexo A: A.5.15, A.8.3. Estado: propuesto, no probado.

7.12. R12 Contenido oculto por esteganografía

Elemento	Descripción
Activo	A12 Módulo de esteganografía. Dimensiones: I, C.
Amenaza	Un participante oculta información dentro de una imagen para eludir la política de contenido.
Vulnerabilidad	Sin análisis, o detector único sin calibrar, y política que publica archivos con resultado dudoso.
Consecuencia	Circula información no autorizada dentro de una imagen aparentemente normal.
Probabilidad	$P = 3$: ocultar datos es accesible, pero depende de la técnica y del detector.
Impacto	$I = 4$: se incumple un requisito central y puede salir información reservada.
Riesgo inherente	$3 \times 4 = 12$ – Medio-Alto
Control	Análisis específico para PNG y JPEG (por ejemplo, pruebas estadísticas sobre bits menos significativos); documentar técnicas y umbrales; resultados sospechosos o dudosos quedan en cuarentena con alerta; registrar el resultado junto al hash del archivo.
Prueba	Evaluar un conjunto de imágenes limpias y alteradas (con diferentes cargas ocultas): medir falsos negativos y falsos positivos. Si el detector falla o no responde, el archivo no se publica.
Riesgo residual	$2 \times 3 = 6$ – Medio-Bajo. P baja solo si se cumplen los umbrales del conjunto de prueba; I baja a 3 porque la cuarentena frena la circulación.
Riesgo que queda	Técnicas no cubiertas o cargas muy pequeñas pueden dar falsos negativos. No se afirma detección universal.
Trazabilidad	RF08; POL06; Anexo A: A.8.16, A.8.29. Estado: propuesto, no probado.

7.13. R13 Manipulación de auditoría

Elemento	Descripción
Activo	A13 Registros de auditoría. Dimensiones: I, D.
Amenaza	Un intruso borra o modifica registros para ocultar sus acciones.
Vulnerabilidad	Registros solo locales y modificables por la misma cuenta del servicio.
Consecuencia	No se puede reconstruir quién hizo qué ni cuándo.
Probabilidad	$P = 3$: requiere acceso previo, pero una cuenta con permiso de borrado lo facilita.
Impacto	$I = 4$: la pérdida de evidencia afecta la investigación en todas las salas.
Riesgo inherente	$3 \times 4 = 12$ – Medio-Alto
Control	Envío de eventos a un destino separado con credencial de solo inserción; hora sincronizada; hash encadenado entre registros; alerta si dejan de llegar eventos; no registrar contraseñas, tokens ni texto de mensajes.
Prueba	Intentar borrar o editar registros con la cuenta del chat: denegado. Detener el envío: se genera alerta en minutos.
Riesgo residual	$1 \times 4 = 4$ – Bajo. P baja a 1 porque la cuenta del chat no puede alterar el destino.
Riesgo que queda	Eventos que nunca se emitieron durante un compromiso, o compromiso del recolector.
Trazabilidad	RF09; POL07; Anexo A: A.8.15, A.8.16. Estado: propuesto, no probado.

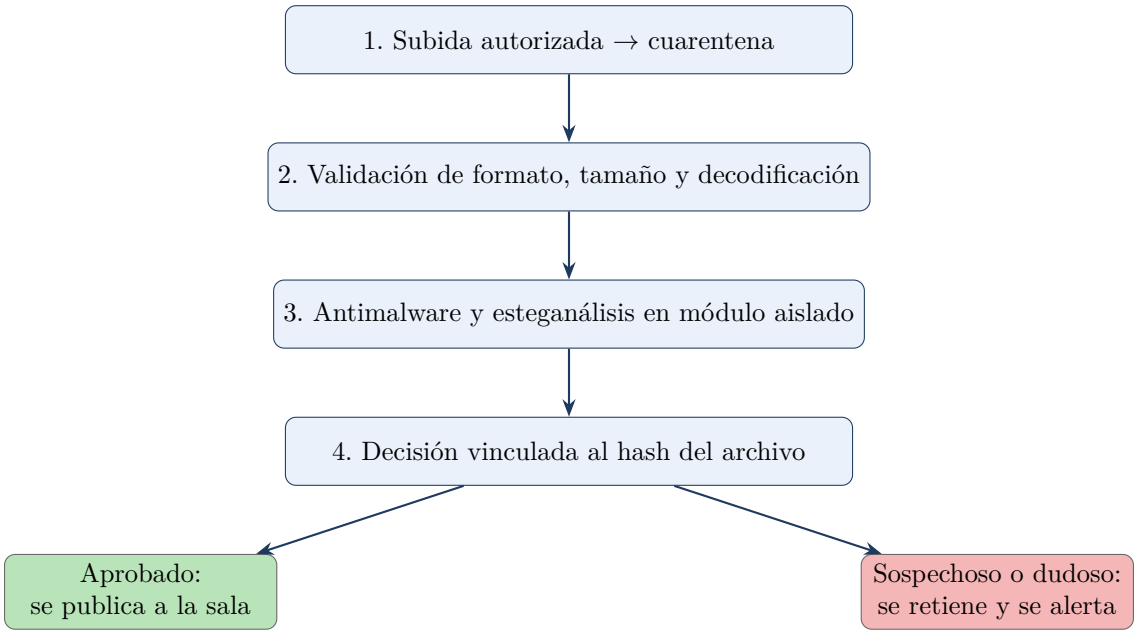
7.14. R14 Inyección SQL

Elemento	Descripción
Activo	A14 Base de datos. Dimensiones: C, I, D.
Amenaza	Un atacante altera las consultas mediante datos de entrada (identificadores, filtros, nombres).
Vulnerabilidad	Consultas construidas concatenando texto sin parametrizar.
Consecuencia	Lectura o modificación no autorizada de salas, membresías y claves.
Probabilidad	$P = 4$: es una técnica muy conocida y las entradas del chat son numerosas. No se asigna 5 porque aún no hay código con explotación reproducida.
Impacto	$I = 4$: afecta datos de varias salas; se evita el nivel 5 porque se guardan hashes y no claves en claro.
Riesgo inherente	$4 \times 4 = 16$ – Alto
Control	Consultas parametrizadas en todo acceso a datos; listas permitidas para ordenamientos; usuario de base con mínimo privilegio; errores sin detalles internos; SAST y DAST en cada entrega.
Prueba	Casos con comillas, operadores y tipos inválidos en cada entrada: no cambian la consulta ni revelan datos. Revisar los permisos de la cuenta de base de datos.
Riesgo residual	$2 \times 3 = 6$ – Medio-Bajo. I baja a 3 porque el mínimo privilegio limita qué tablas puede tocar la aplicación.
Riesgo que queda	Rutas nuevas sin revisar o credenciales de base de datos comprometidas.
Trazabilidad	RF02, RF03, RF05; POL05; Anexo A: A.8.28, A.8.3. Estado: propuesto, no probado.

7.15. R15 Denegación de servicio (DoS)

Elemento	Descripción
Activo	A15 Servidor backend y APIs. Dimensión: D.
Amenaza	Un atacante inunda el servidor con conexiones, mensajes o archivos hasta agotar sus recursos.
Vulnerabilidad	Sin límites de tasa, de tamaño ni de cantidad de conexiones por identidad o globales.
Consecuencia	Los usuarios legítimos no pueden entrar ni chatear.
Probabilidad	$P = 4$: repetir conexiones y mensajes tiene bajo costo.
Impacto	$I = 4$: la interrupción puede durar varias horas en el entorno del piloto.
Riesgo inherente	$4 \times 4 = 16$ – Alto
Control	Límites de tasa por identidad y origen; tamaño máximo de mensaje; cupo global de conexiones; aforo atómico por sala; colas acotadas para archivos; monitoreo y alertas de saturación; plan de recuperación.
Prueba	Prueba de carga en entorno aislado (50 usuarios legítimos y varios clientes de abuso): se rechaza el exceso, se mantiene el servicio para los legítimos y se recupera tras el ataque.
Riesgo residual	$2 \times 4 = 8$ – Medio-Bajo. P baja a 2; I sigue en 4.
Riesgo que queda	Un ataque distribuido o volumétrico contra el proveedor excede lo que controla el backend.
Trazabilidad	RF03, RF06, RF07; POL08; Anexo A: A.8.6, A.8.16. Estado: propuesto, no probado.

8. Flujo de archivos y límites de la protección



- **Integridad del proceso:** se publica exactamente el archivo analizado; se compara su hash SHA-256 para evitar que sea sustituido entre el análisis y la descarga. El hash identifica los bytes, pero por sí solo no detecta esteganografía ni autentica al remitente.
- **Cifrado y análisis:** se usa TLS entre cliente y servidor y cifrado autenticado en reposo. No se afirma cifrado de extremo a extremo, porque el servidor necesita ver la imagen para analizarla.

- **Esteganografía:** ocultar datos no significa necesariamente malware. La política es restringir contenido oculto y alertar ante indicios. Ningún detector es perfecto; por eso se miden y reportan sus fallos.

9. Plan de tratamiento y gestión residual

Etapa	Riesgos	Criterio de salida
1. Diseño	Todos; RF01–RF09; POL01–POL08	Aprobar identidad estable, matriz de roles, formatos y cuotas.
2. Acceso y comunicación	R01–R09	Pruebas de acceso, sesiones, aforo, revocación y TLS; secretos fuera del código.
3. Contenido y datos	R10–R14	Pruebas de carga de archivos, esteganálisis, autorización de descarga y consultas.
4. Operación y entrega	R13, R15 y transversales	Carga, logs, alertas y restauración; recalcular los residuales.

Estado de los residuales. Los 15 residuales son objetivos: se confirman solo si pasan las pruebas indicadas en cada ficha. Un control configurado y sin probar se considera "implementado, pendiente de verificación".

Riesgos que más preocupan. Aunque ninguno queda alto, R01, R02, R04, R10 y R15 conservan residual 8, el más alto del registro. Se priorizan para pruebas y revisión quincenal. Si alguna prueba falla, el riesgo vuelve a su valoración anterior y no se libera el componente.

Ciclo de revisión. Se mantiene un registro con ID, versión, responsable, P e I iniciales y residuales, control, evidencia, decisión y próxima revisión. Se revisa al final de cada iteración, ante incidentes y al cambiar bibliotecas, formatos o topología.

10. Indicadores de seguimiento

Todos los indicadores están pendientes de medición. Un denominador cero se registra como "sin muestra", nunca como éxito.

ID	Indicador	Cómo se mide	Meta
K01	Cobertura de MFA	Administradores con MFA / administradores activos	100 %
K02	Rechazo de segunda sesión	Pares de conexión con una sola activa / pares ensayados	100 % en 100 pares
K03	Pruebas de permisos	Casos correctamente denegados / casos negativos ejecutados	100 % del plan
K04	Transporte protegido	Rutas con TLS válido / rutas inventariadas	100 % HTTPS/WSS
K05	Publicación aprobada	Archivos publicados con aprobación ligada a su hash / archivos publicados	100 %
K06	Fallos del esteganálisis	(Alterados aceptados + dudosos) / alterados ensayados	≤ 5 % por formato
K07	Bloqueo de imágenes limpias	(Limpios sospechosos + dudosos) / limpios ensayados	≤ 10 % por formato

ID	Indicador	Cómo se mide	Meta
K08	Latencia bajo abuso	Percentil 95 de entrega de mensajes legítimos en la prueba de carga	< 2 s, sin caída
K09	Cobertura de auditoría	Eventos recibidos / eventos obligatorios generados en ensayo	100 %; alerta en ≤ 5 min
K10	Vulnerabilidades críticas abiertas	Hallazgos críticos confirmados sin corregir	0 al liberar

Sobre K06 y K07. Los resultados "dudosos" se cuentan como fallo para no mejorar los números por abstención. Se recomienda un conjunto de prueba con al menos 100 imágenes alteradas por técnica y 100 limpias por formato, de fuentes separadas de las usadas para ajustar el detector. Son mínimos de ensayo, no garantía estadística de producción.

11. Conclusiones

El análisis convierte los requisitos de KunturChat en 15 escenarios de riesgo, cada uno con activo, amenaza, vulnerabilidad, valoración, control y prueba. Sin tratamiento hay 9 riesgos altos y 6 medio-altos; con los controles propuestos, el objetivo es 12 medio-bajos y 3 bajos.

Los puntos más delicados son la identidad (necesaria para aplicar la sesión única), el alcance de las claves y de la administración, y la limitación inherente del esteganálisis. Las cifras residuales son metas de diseño: se actualizarán con la evidencia de las pruebas y con la implementación real.

Referencias

[1] Proyecto integrador: resumen de una aplicación de salas de chat seguras. Material de la asignatura Desarrollo de Software Seguro, ESPE.

[2] ISO/IEC. (2022). *ISO/IEC 27001:2022. Information security management systems – Requirements.*

[3] ISO/IEC. (2022). *ISO/IEC 27005:2022. Guidance on managing information security risks.*

[4] ISO/IEC. (2011). *ISO/IEC 27034-1:2011. Application security – Part 1: Overview and concepts.*

[5] Rose, S., Borchert, O., Mitchell, S. y Connelly, S. (2020). *Zero Trust Architecture.* NIST SP 800-207. https://doi.org/10.6028/NIST.SP.800-207

[6] OWASP Foundation. *Session Management Cheat Sheet.* https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html

[7] OWASP Foundation. *Password Storage Cheat Sheet.* https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html

[8] OWASP Foundation. *WebSocket Security Cheat Sheet.* https://cheatsheetseries.owasp.org/cheatsheets/WebSocket_Security_Cheat_Sheet.html

[9] OWASP Foundation. *SQL Injection Prevention Cheat Sheet.* https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

[10] OWASP Foundation. *File Upload Cheat Sheet.* https://cheatsheetseries.owasp.org/cheatsheets/File_Upload_Cheat_Sheet.html

[11] OWASP Foundation. *Logging Cheat Sheet.* https://cheatsheetseries.owasp.org/cheatsheets/Logging_Cheat_Sheet.html

[12] Rescorla, E. (2018). *The Transport Layer Security Protocol Version 1.3.* RFC 8446. https://www.rfc-editor.org/info/rfc8446